INSTITUT PUIG CASTELLAR

A03. Exercicis: Seguretat lògica

0226. Seguretat informàtica	GRUP: SMX2C
RA1. Aplica mesures de seguretat passiva en sistemes informàtics descrivint característiques d'entorns i relacionant-les amb les seves necessitats.	
NOM I COGNOMS: Posa el teu nom i cognoms.	**DATA:** Escriu la data.

Enunciat de l'activitat:

Aquesta activitat es cenyeix exclusivament al subtema 3 (Seguretat lògica) del RA1: control d'accés, gestió i protecció de contrasenyes, tipus d'autenticació, permisos avançats en sistemes UNIX i registres del sistema. Alguns exercicis requereixen fer una petita recerca a Internet o instal·lar programari; l'últim es planteja com un cas pràctic complet. Respon de manera clara i justificada, citant les fonts que consultis. S'hi han incorporat també els continguts més recents (identificació, gestors de contrasenyes, autenticació sense contrasenya, models d'autorització MAC i RBAC) i una part pràctica guiada a Ubuntu sobre política de contrasenyes amb PAM, el fitxer /etc/shadow, auditoria amb John the Ripper i xifratge amb GPG.

Lliurament de captures: sempre que un exercici impliqui treballar amb terminal, cal lliurar una captura de les ordres executades i el seu resultat. Es recomana realitzar tota la pràctica des d'una màquina virtual d'Isard (IsardVDI), per disposar dels permisos necessaris per executar totes les ordres i evitar que l'historial de la sessió s'esborri entre exercicis.

Enunciat exercici 1

Els usuaris Oriol, Raquel i Ramon són propietaris dels fitxers fitxer1, fitxer2 i fitxer3, respectivament, i cadascun té control total sobre el seu propi fitxer. A més: l'Oriol ha concedit permís de lectura i escriptura a en Ramon i la Raquel sobre fitxer1; la Raquel ha denegat qualsevol accés al seu fitxer (fitxer2) a la resta; en Ramon ha concedit accés de lectura a l'Oriol i de lectura i escriptura a la Raquel sobre fitxer3.

a) Construeix la matriu de control d'accés per als subjectes Oriol, Raquel i Ramon i els objectes fitxer1, fitxer2 i fitxer3.

b) A partir de la matriu, indica quina seria la llista de control d'accés (ACL) d'un dels objectes.

c) Indica quines serien les capacitats d'un dels subjectes.

Enunciat exercici 2

a) Enumera almenys cinc normes bàsiques que cal seguir per protegir una contrasenya un cop creada.

b) Completa amb les teves paraules: una política de contrasenyes és un document que regula...

c) Explica què és un fals positiu i un fals negatiu en un sistema d'autenticació, posant un exemple de cadascun.

Enunciat exercici 3

a) Descarrega i instal·la l'eina de programari lliure KeePass (o KeePassXC) i enumera quines funcionalitats ofereix per facilitar la gestió de contrasenyes.

📷 *Lliurament: captura de les ordres executades i el resultat.*

b) Cerca informació sobre l'eina John the Ripper: quin mecanisme fa servir per esbrinar contrasenyes? Explica per què una contrasenya no hauria de ser mai una paraula que aparegui en un diccionari.

Enunciat exercici 4

a) Proposa dos exemples propis (diferents dels vistos a classe) per a cadascun dels tres tipus d'autenticació: per coneixement, per possessió i per característica.

b) Enumera els tipus de sistemes biomètrics més habituals.

Enunciat exercici 5

a) Cerca informació sobre l'sticky bit en sistemes UNIX/Linux: per a què s'utilitzava abans? Quina utilitat té actualment? Quina ordre cal utilitzar per activar-lo en un directori?

Abans de continuar: per fer la comprovació necessitaràs dos usuaris de prova al sistema, alex i marina. Investiga quina ordre de Linux permet crear un usuari nou (amb el seu directori personal) i crea'ls al teu equip.
Un cop fet, comprova-ho tu mateix: crea un directori propi, activa-hi el sticky bit i demostra'n l'efecte intentant esborrar, amb un altre usuari, un fitxer que no és seu dins d'aquell directori.

```
$ mkdir prova_sticky
$ ls -ld prova_sticky
drwxr-xr-x 2 joan joan 4096 oct  5 06:53 prova_sticky

$ chmod +t prova_sticky
$ ls -ld prova_sticky
drwxr-xr-t 2 joan joan 4096 oct  5 06:53 prova_sticky

$ chmod 1777 prova_sticky
$ sudo su alex -c "touch prova_sticky/fitxer_alex.txt"
$ sudo su marina -c "rm prova_sticky/fitxer_alex.txt"
rm: cannot remove 'prova_sticky/fitxer_alex.txt': Operation not permitted
```

Captura real: creació del directori, activació del sticky bit (la t final als permisos), i la prova amb dos usuaris diferents: l'Alex crea un fitxer dins el directori compartit, i la Marina no el pot esborrar encara que el directori sigui d'escriptura per a tothom.



📷 *Lliurament: captura de les ordres executades i el resultat.*

b) Cerca informació sobre les eines SIM (system integrity monitor): quins avantatges ofereixen per a la gestió de registres, i quin parell de productes d'aquest tipus coneixes?

c) Esbrina quina eina ofereix el teu sistema operatiu per visualitzar els esdeveniments enregistrats i anota'n els quatre darrers.

Enunciat exercici 6

L'empresa EverPia ha patit una fuita d'informació (data breach): un dels comptes tècnics va ser compromès per l'ús d'una contrasenya feble o reutilitzada. Com a resposta, la direcció tècnica ha decidit que tot el personal ha d'utilitzar un gestor de contrasenyes validat.

Elabora un informe que inclogui:

1) Per què les contrasenyes febles o reutilitzades són un risc crític (atacs de diccionari, credential stuffing...) i quina funció té un gestor de contrasenyes per mitigar-los.

2) Una taula comparativa entre Bitwarden (opció al núvol) i KeePassXC (opció d'escriptori): sincronització, model de seguretat, facilitat d'accés, cost, emmagatzematge local i independència del núvol.

3) Avantatges i inconvenients de cada model (online vs. offline) pel que fa a seguretat, usabilitat i continuïtat del negoci.

4) La teva recomanació final, justificada.

Si tens temps i l'eina instal·lada, pots ampliar l'informe amb una petita guia d'ús amb captures de pantalla (instal·lació, generador de contrasenyes, còpia de seguretat).

Enunciat exercici 7 — Identificació, autenticació i autorització

a) Explica, amb un exemple propi (diferent del de l'hotel vist a classe), la diferència entre identificar-se,

autenticar-se i autoritzar-se.

b) Raona per què un nom d'usuari (identificació) no hauria de ser mai, per si sol, suficient per accedir a un sistema.

c) Explica la diferència entre un control d'accés local (per exemple, els comptes d'un PC domèstic) i un de centralitzat (per exemple, un compte corporatiu d'Active Directory o un compte de Google), i indica un avantatge i un inconvenient de cadascun.

Enunciat exercici 8 — Entropia i política de vigència de les contrasenyes

a) Calcula quantes combinacions possibles té una contrasenya de 6 caràcters si només s'hi permeten lletres minúscules (26 símbols), i quantes si també s'hi permeten majúscules (52 símbols). Repeteix el càlcul per a una contrasenya de 12 caràcters només amb minúscules i compara els quatre resultats: quin dels dos factors (longitud o varietat de símbols) fa créixer més ràpidament el nombre de combinacions?

b) Cerca informació sobre per què organismes com el SANS Institute ja no recomanen obligar a canviar la contrasenya periòdicament sense motiu.

c) Explica per a què serveixen el bloqueig de compte després d'intents fallits i l'historial de contrasenyes, i per què continuen sent útils encara que el consell sobre la caducitat hagi canviat.

Enunciat exercici 9 — Tècniques d'atac a les contrasenyes

a) Explica la diferència entre un atac de força bruta, un atac de diccionari i un atac amb rainbow tables.

b) Relaciona cadascuna d'aquestes tècniques amb una eina real (per exemple, John the Ripper, Ophcrack o Medusa) i explica breument què fa cadascuna.

c) Cerca informació sobre el cas del clonatge de l'empremta digital d'una ministra alemanya a partir de fotografies, i sobre la filtració de contrasenyes d'Ashley Madison (2015): què tenen en comú aquests dos casos pel que fa a la manera com es va comprometre la seguretat?

Enunciat exercici 10 — Autenticació sense contrasenya

a) Explica què és un passkey (estàndard FIDO2) i per què es considera més segur que una contrasenya.

b) Un/a company/a de classe assegura que un passkey és, a la pràctica, el mateix que una targeta d'identificació clàssica: "és un objecte físic que t'identifica, i prou". Explica per què aquesta afirmació no és del tot correcta, tenint en compte què passa si algú intenta clonar físicament cadascun dels dos dispositius.

c) Anomena dos dispositius físics reals compatibles amb FIDO2.

Enunciat exercici 11 — Models d'autorització i privilegis

a) Explica la diferència entre els models DAC, MAC i RBAC, indicant en cada cas QUI decideix els permisos.

b) Proposa un exemple propi (diferent del vist a classe) d'un sistema on tingui sentit aplicar MAC, i un altre on tingui sentit aplicar RBAC.

c) Explica la diferència entre un permís (com els de rwx) i un privilegi del sistema, i posa un exemple de cadascun.

Enunciat exercici 12 — Imposar una política de contrasenyes robusta amb PAM

El mòdul PAM pam_pwquality permet que el sistema operatiu REBUTGI automàticament les contrasenyes que no compleixin uns criteris mínims, en lloc de confiar que l'usuari segueixi les recomanacions per voluntat pròpia. Entorn recomanat: Ubuntu 26.04 (o una màquina virtual amb qualsevol distribució derivada de Debian/Ubuntu).

Pas 1. Instal·la el mòdul de qualitat de contrasenyes:

```
$ sudo apt install libpam-pwquality
```

Pas 2. Edita /etc/security/pwquality.conf i afegeix (o descomenta i modifica) aquests paràmetres:

```
minlen = 10        # longitud mínima
minclass = 3       # mínim de classes de caràcters diferents (majúscules,
                   # minúscules, dígits, símbols) d'un total de 4
dictcheck = 1      # rebutja contrasenyes basades en paraules de diccionari
maxrepeat = 3      # màxim de caràcters idèntics consecutius
```

Pas 3. Comprova que el mòdul està enllaçat a la cadena de canvi de contrasenya (hauria d'aparèixer a /etc/pam.d/common-password, abans de la línia de pam_unix.so):

```
$ grep pwquality /etc/pam.d/common-password
password    requisite    pam_pwquality.so retry=3
```

Si no hi apareix, executa "sudo pam-auth-update" i assegura't que l'opció "Pwquality password strength checking" estigui activada.

Pas 4. Crea un usuari de prova i intenta canviar-li la contrasenya per una de feble i, després, per una de robusta:

Captura real: primer intent, amb una contrasenya feble ("contrasenya123", només dues classes de caràcters) — pam_pwquality la rebutja dues vegades i "passwd" acaba abortant el canvi. Segon intent, amb una contrasenya robusta ("Tard0r-Blava!42") — s'accepta correctament.



Reprodueix aquest experiment al teu equip, primer amb un usuari de prova propi, i respon:

📷 *Lliurament: captura de les ordres executades i el resultat.*

a) Quantes vegades et deixa “passwd” fallar abans d’avortar el canvi, i amb quin paràmetre de configuració es relaciona?

b) Repeteix el canvi de contrasenya com a ROOT (amb “sudo passwd usuari” en lloc de “passwd”): s’aplica igual la política? Per què creus que hi ha aquesta diferència de comportament?

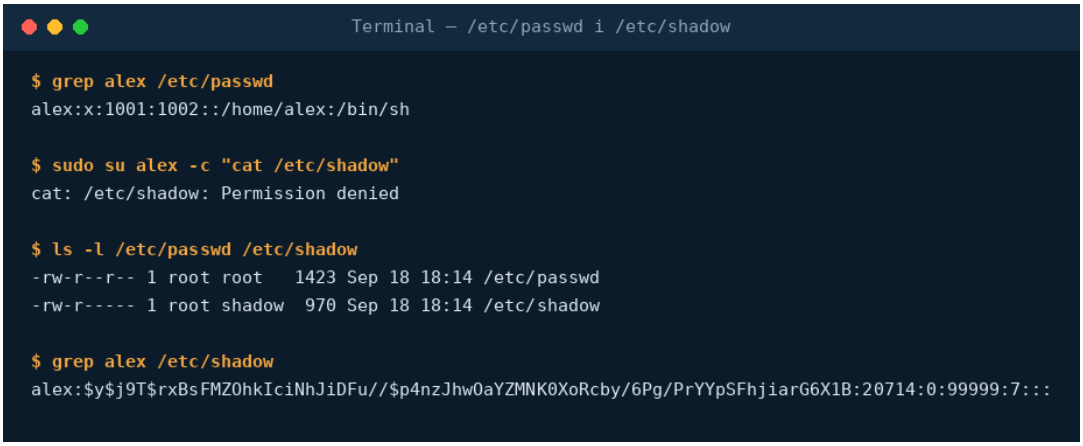
Enunciat exercici 13 — Els fitxers /etc/passwd i /etc/shadow

Linux guarda la informació de tots els comptes d’usuari en dos fitxers de text molt concrets. Entendre’n l’estructura és la base de tot el que ve després.

Pas 5-7. Consulta un usuari a /etc/passwd, intenta llegir /etc/shadow com a usuari normal i, finalment, consulta’l amb “sudo”, comparant els permisos dels dos fitxers:

```
$ grep alex /etc/passwd
$ sudo su alex -c "cat /etc/shadow"
$ ls -l /etc/passwd /etc/shadow
$ sudo grep alex /etc/shadow
```

Captura real: /etc/passwd es pot llegir sense problemes com a usuari normal, però intentar llegir /etc/shadow dóna “Permission denied”. Els permisos ho confirmen: /etc/passwd és -rw-r--r-- (tothom en lectura), mentre que /etc/shadow és -rw-r----- i pertany al grup “shadow” (només root, o qui pertanyi a aquest grup, hi pot accedir).



Cada línia de /etc/passwd té 7 camps separats per ":" — nom d'usuari, contrasenya (sempre "x", ja que el hash real és a /etc/shadow), UID, GID, comentari (GECOS), directori personal i intèrpret d'ordres. Cada línia d'/etc/shadow, en canvi, en té 9: nom d'usuari, hash de la contrasenya, dia del darrer canvi (des de l'1/1/1970), dies mínims i màxims entre canvis, dies d'avís abans de caducar, dies de gràcia, dia de caducitat del compte, i un camp reservat.

a) Per què té sentit que qualsevol usuari pugui llegir /etc/passwd, però no /etc/shadow? Relaciona-ho amb els permisos (rwx) i el grup propietari de cada fitxer.

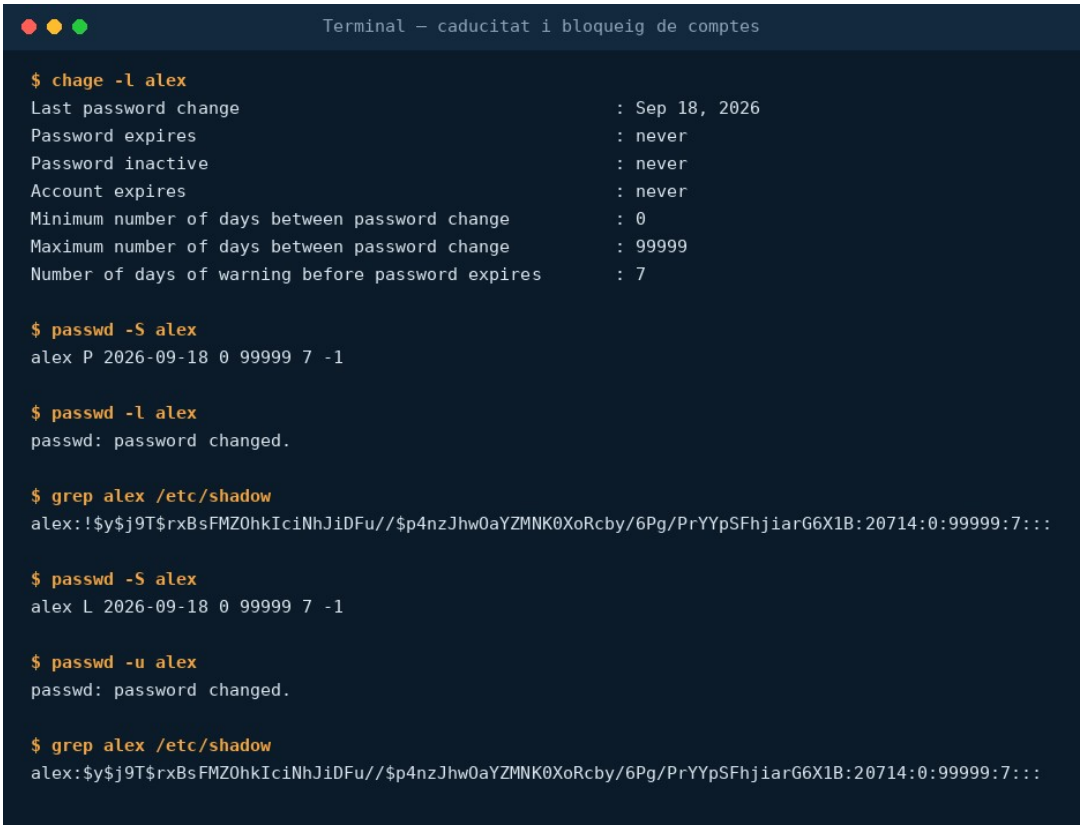
b) Quin prefix té l'algorisme de hash de la teva distribució a /etc/shadow, i per què es considera que MD5 ja no és adequat per a aquest ús?

Abans de continuar: perquè el Pas 8 tingui sentit (comprovar l'estat d'un compte i el cicle de bloqueig/desbloqueig), assigna primer una contrasenya a l'usuari alex, si encara no en té cap.
Pas 8. Consulta la caducitat d'un compte amb "chage" i "passwd -S", i prova el cicle de bloqueig i desbloqueig:

```
$ chage -l alex
$ passwd -S alex
$ sudo passwd -l alex     # bloquejar
$ sudo passwd -u alex     # desbloquejar
```

Captura real: "chage -l" tradueix els dies des de 1970 a dates llegibles; "passwd -S" mostra l'estat en una sola línia. En bloquejar el compte, el hash de /etc/shadow queda precedit per un "!" (la contrasenya deixa de ser vàlida, però no s'esborra); en desbloquejar-lo, el "!" desapareix i el compte torna a funcionar amb la mateixa contrasenya d'abans.

📷 *Lliurament: captura de les ordres executades i el resultat.*



c) Quina diferència pràctica hi ha entre bloquejar un compte (“passwd -l”) i esborrar-lo (“userdel”)? Indica una situació real on tindria sentit cadascuna.

d) Si un usuari amb el compte bloquejat intenta iniciar sessió, quin missatge creus que rebrà?

Enunciat exercici 14 — Auditoria de contrasenyes amb John the Ripper

Imposar una bona política evita contrasenyes noves febles, però no soluciona les que ja existien abans. Una pràctica habitual en auditories de seguretat és intentar “trencar” els propis hashos de contrasenyes per detectar comptes vulnerables abans que ho faci un atacant real.

Abans de continuar: assigna a la marina una contrasenya feble que coincideixi amb alguna de les paraules que posaràs al wordlist del Pas 10 (per exemple, una basada en “futbol” + números), perquè puguis reproduir l'atac de diccionari sobre un cas real. Fes-ho abans de continuar amb el Pas 9, ja que aquest capturarà el hash tal com estigui en aquell moment.

Pas 9. Instal·la John the Ripper (si encara no ho has fet) i combina /etc/passwd i /etc/shadow en un únic fitxer amb el format que espera:

```
$ sudo apt install john
$ sudo unshadow /etc/passwd /etc/shadow > hashes.txt
```

Pas 10. Prepara una llista de paraules (“wordlist”) amb candidats plausibles, extreu del fitxer combinat únicament el hash de l'usuari que vols atacar, i llança John the Ripper contra aquest hash:

```
$ cat > mini_wordlist.txt << EOF
futbol
```

```
futbol1
futbol12
futbol99
futbol2024
barcelona
madrid
football
soccer99
password
123456
qwerty
EOF

$ grep ^marina: hashes.txt > marina_hash.txt

$ john --format=crypt --wordlist=mini_wordlist.txt marina_hash.txt
$ john --show marina_hash.txt
```

Captura real: amb una llista de només 12 paraules plausibles, John the Ripper troba la contrasenya de l'usuària "marina" ("futbol99") en menys d'un segon. En canvi, la mateixa llista aplicada a l'usuari "david" (contrasenya aleatòria "xQ9#vLp2Zr!8") no troba res.



Crea dos usuaris de prova propis amb contrasenyes diferents (una basada en una paraula comuna + números, una altra generada aleatòriament amb símbols) i repeteix l'experiment. Respon:

📷 *Lliurament: captura de les ordres executades i el resultat.*
a) Per què creus que la contrasenya “feble” es troba en fraccions de segon, mentre que la “robusta” resisteix el mateix atac?

b) Si en lloc d’una llista de 12 paraules féssim servir un diccionari complet (amb més de 100.000 paraules) i regles de mutació (“--rules”), creus que la contrasenya robusta acabaria caient igualment, encara que trigués més temps? Raona la resposta relacionant-la amb el concepte d’“espai de claus” (nombre de combinacions possibles).

Enunciat exercici 15 — Xifratge de fitxers confidencials amb GPG

Una bona política de contrasenyes protegeix l’ACCÉS al sistema, però no protegeix el CONTINGUT d’un fitxer si algú hi accedeix per una altra via (per exemple, robant una còpia de seguretat, o accedint físicament al disc). Per a això cal xifrar directament els fitxers sensibles.

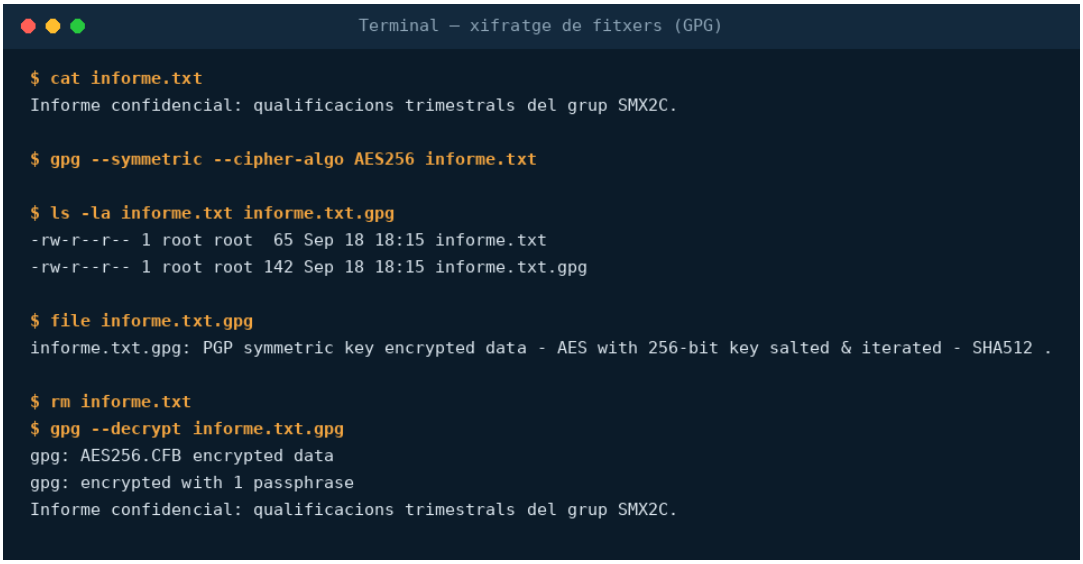
Pas 11. Crea un fitxer de prova i xifra'l amb GPG, utilitzant xifratge simètric (una única contrasenya) amb l'algorisme AES-256:

```
$ echo "Informe confidencial: qualificacions trimestrals del grup SMX2C." >
informe.txt
$ gpg --symmetric --cipher-algo AES256 informe.txt
```

Pas 12. Comprova que el contingut xifrat és realment il·legible, i finalment desxifra’l:

```
$ file informe.txt.gpg
$ rm informe.txt          # simulem que només queda la còpia xifrada
$ gpg --decrypt informe.txt.gpg
```

Captura real: xifratge d’un informe confidencial amb GPG/AES-256, comprovació que el fitxer resultant és binari xifrat (no un .txt), esborrat del fitxer original, i desxifratge correcte introduint la contrasenya.



Reprodueix-ho amb un fitxer propi i respon:

📷 *Lliurament: captura de les ordres executades i el resultat.*
a) Si perds o oblides la contrasenya de xifratge, es pot recuperar el contingut del fitxer per cap altra via? Per

què això és, alhora, un avantatge de seguretat i un risc operatiu?

b) Compara aquest xifratge SIMÈTRIC (una contrasenya compartida) amb el xifratge ASIMÈTRIC (parell de claus pública/privada): per a quin escenari series més adequat cadascun — protegir un únic fitxer personal, o enviar un fitxer xifrat a un company sense haver-li de dir la contrasenya per telèfon o correu?

Enunciat exercici 16 — Cas pràctic final: el despatx d'advocats

Ets el tècnic informàtic d'un petit despatx d'advocats (8 treballadors) que acaba de patir un ensurt: un antic empleat, acomiadat fa un mes, encara podia accedir remotament a un compte compartit perquè ningú havia canviat la contrasenya ("Despatx2020", sense variacions des de la creació del compte fa anys) NI havia bloquejat el seu compte personal el dia de la baixa.

Elabora un informe tècnic que reculli:

1) Una política de contrasenyes concreta (paràmetres de pwquality) que proposaries implantar per a tots els comptes del despatx, justificant cada paràmetre.

2) Què hauria d'haver fet el departament tècnic el mateix dia de l'acomiadament amb el compte de l'antic empleat (relaciona-ho amb "passwd -l" i amb la diferència entre bloquejar i esborrar un compte).

3) Un procediment d'auditoria periòdica (per exemple, trimestral) per detectar contrasenyes febles entre els comptes ja existents, utilitzant les eines d'aquesta activitat.

4) Quins expedients o documents (per exemple, informes de casos amb dades de clients) recomanaries xifrar addicionalment amb GPG, més enllà de protegir-los només amb un usuari i contrasenya.

5) Un protocol complet de "baixa" d'empleats que eviti que una situació com aquesta es pugui repetir.

Lliurament final — Historial de comandes

Un cop finalitzats tots els exercicis pràctics (12 a 16), abans de lliurar la pràctica cal aportar una darrera captura: l'historial complet de totes les ordres que has executat al terminal al llarg de tota la pràctica.

```
$ history
```

La captura ha de mostrar la llista completa d'ordres de la sessió, incloent-hi la mateixa ordre history. Fes-ho sense tancar el terminal entre exercicis, per tal que l'historial no es perdi abans d'arribar al final de la pràctica.

Fonts: *Institut Obert de Catalunya (IOC), Mòdul "Seguretat informàtica", Unitat 1, apartat 3 – Activitats (u1/a3/activitats.html) i Exercicis d'autoavaluació (u1/a3/exercicis.html); repositori NF1AA3-GestorContrasenyes (GitHub, SMX-0226SI); repositori NF1/AA3-SeguretatLogica (GitHub, SMX-0226SI/Materials); documentació oficial de libpam-pwquality (manpages Debian/Ubuntu); John the Ripper (openwall.com/john); GnuPG (gnupg.org).*